VyaparSetu: Data Privacy & Security Note

Airtel Sync 2026 · Enterprise Track A (Project Udyam Digital) · Team Hacker_247, ABV-IIITM Gwalior · Digital Personal Data Protection Act, 2023

WHAT WE COLLECT, AND WHY

Business and owner name, mobile number, city, GSTIN, Udyam number, address-proof date and signatory-ID name/validity. **Only** to verify the business, check serviceability and create the order. All hackathon data is synthetic and the registries are mock files.

BUILT AND VERIFIED IN THE PROTOTYPE

Principle	What the running system does
Consent (s.5-6)	Upload and verification stay locked until the owner ticks a plain-language consent. Every grant, revocation and purge is appended to a ledger with consent ID, timestamp, purpose, retention period and a SHA-256 audit hash, stored in Neon Postgres.
Withdrawal	A revoke call halts processing at once and a purge job issues deletion receipts (also written to the ledger).
Minimisation (s.8)	Documents are read in memory and are never written to disk or the database. We keep extracted fields and the verdict only. 4 MB cap per file, PDFs rejected. GSTINs are masked (PAN part hidden) in responses and reasons.
Purpose limitation (s.7)	Data feeds only the KYC rules, serviceability and the order. No marketing use and no sharing outside the processors below.
Access to orders	The tracker needs the order number *and* the registered mobile. The server gives one identical "not found" for a wrong number or an unknown order, so ids cannot be probed.

SUB-PROCESSORS (DISCLOSED)

- **Google Gemini API**: reads document images (text transcription) and understands the advisor's free-text, over TLS. Images are sent only for that call and not stored by us. The free tier is used for the prototype; production should use a zero-data-retention agreement or an on-premise OCR model.
- **Neon Postgres** (orders, consent ledger) and **Vercel** (hosting). Both encrypt in transit; Neon also encrypts storage at rest.

KNOWN LIMITS AND THE PRODUCTION PLAN (NOT YET BUILT)

- **No customer login.** Production: mobile OTP sessions in place of order number + mobile.
- **Partner portal is open demo data.** Production: SSO and role-based access; partners see status only, never raw documents.
- **Purge is a callable job, not yet scheduled.** Production: automatic deletion 30 days after activation, keeping only the hash and registry transaction ID.
- **Field-level encryption** of mobile numbers and ledger entries, log scrubbing of identifiers, and a breach-notification runbook are planned.
- **Signatory ID:** never request or store a full Aadhaar number. Production should use a DigiLocker consent flow instead of image upload.
- Data-principal rights screens (access, correction, grievance officer) are required by the Act and are on the roadmap.

> We state the limits openly: the controls above marked "built" were exercised by tests and live checks; the rest is design intent, not a claim.